bringing both sides of the entity into compliance with the proposed amendments would impose a significant burden and require a dual registrant to modify both sides of the entity' compliance frameworks.[731] We do not expect a significant burden, because we expect that these institutions could generally implement a single set of procedures to comply with many of the provisions of the final amendments, which would limit these additional burdens.[732] To the extent entities registered as more than one category of covered institution arrange their business such that there are separate policies and procedures for each category, those entities may encounter additional cost burden when complying with the final amendments. For example, an entity that creates two different incident response programs for its advisory and broker-dealer operations could bear as much as twice the cost burden as the same entity would bear when creating one incident response program,[733] although there may be efficiencies to the extent that development of one program informs the other. The final amendments, however, do not prevent that entity from using the same incident response program across its categories of covered institutions.

In the remainder of this section, we first consider the benefits and costs associated with requiring covered institutions to have a response program generally. We then analyze the benefits and the costs of the notification requirements vis-à-vis the notification requirements already in force under the various existing state laws. We conclude this section with an analysis of the benefits and costs of the response program's service provider provisions.

---

731 *See* Cambridge Comment Letter.

732 For example, we expect that these institutions will be able to implement a single set of procedures to satisfy the customer notification requirements.

733 For example, annual average costs of $30,890 associated with preparation of written policies and procedures instead of annual average costs of $15,445. *See, e.g.*, *infra* footnote 856 and accompanying text.

a. Response Program

The final amendments require covered institutions' written policies and procedures to include a response program "reasonably designed to detect, respond to, and recover from unauthorized access to or use of customer information, including customer notification procedures."[734] The response program must address incident assessment, containment, as well as customer notification and oversight of service providers.[735]

The question of how best to structure the response to an incident resulting in unauthorized access to or use of customer information has received considerable attention from firms, IT consultancies, government agencies, standards bodies, and industry groups, resulting in numerous reports with recommendations and summaries of best practices.[736] While the emphasis of these reports varies, certain key components are common across many incident response programs. For example, NIST's Computer Security Incident Handling Guide identifies four main phases to cyber incident handling: (1) preparation; (2) detection and analysis; (3) containment, eradication, and recovery; and (4) post-incident activity.[737] The assessment, containment, and notification prongs of the final policies and procedures requirements correspond to the latter three phases of the NIST recommendations. Similar analogues are found in other reports, recommendations, and other regulators' guidelines.[738] Thus, the required procedures of the incident response program are substantially consistent with industry best practices and these other regulatory documents that seek to develop effective policies and procedures in this area.

---

[734] Final rule 248.30(a)(3).

[735] *See* final rule 248.30(a)(3).

[736] *See supra* section IV.C.1.

[737] *See* NIST Computer Security Incident Handling Guide.

[738] *See supra* text accompanying footnote 604.

While some commenters suggested that some specific provisions of the amendments be better aligned with existing regulation,[739] other commenters stated that the Commission's proposal would generally align the amendments with other regulatory frameworks such as the Banking Agencies' Incident Response Guidance.[740] One of these commenters stated that consistency across regulatory requirements facilitates firms' operations, provides for efficiencies in their operations, and better serves customers.[741] In the final amendments, we have revised some requirements from the proposal to better align them with existing regulatory framework. For example, one commenter stated that a 72-hour deadline would improve alignment with other existing requirements and that this would significantly reduce complexity and compliance burdens for covered institutions and their service providers.[742] Consistent with other regulatory frameworks,[743] the final amendments require that covered institutions ensure that their service providers take appropriate measures to provide notification to the covered institution as soon as possible, but no later than 72 hours after becoming aware that a breach in security has occurred.[744]

Similar to the written policies and procedures requirement, we expect the benefits and the costs of the response program requirements to vary across covered institutions. In general, costs will be larger for entities that do not have any related incident response programs or related policies and procedures. For those entities, costs may include needing to familiarize themselves with the new requirements, initial set up costs for new systems to monitor when customers need

---

739 *See* SIFMA Comment Letter 2; Computershare Comment Letter.

740 *See, e.g.*, ICI Comment Letter 1; Nasdaq Comment Letter.

741 *See* ICI Comment Letter 1.

742 *See* Microsoft Comment Letter; *see also supra* footnote 245 and accompanying text.

743 *See supra* footnote 257 and accompanying text.

744 The proposed amendments instead had a requirement of 48 hours. *See* Proposing Release at section II.A.3.

to be notified, new notification systems, and development and implementation of new policies and procedures associated with response programs. Therefore, on the one hand, the effects of the requirements are likely to be small for covered institutions with a national presence who are likely to already have such programs in place.[745] For such institutions, we expect direct compliance costs to be largely limited to reviews and, if needed, updates of existing policies and procedures.[746] On the other hand, we expect greater benefits and costs for smaller, more geographically limited covered institutions since they are less likely to have an existing incident response program. The benefits ensuing from these institutions incorporating incident response programs to their written policies and procedures can be expected to arise from improved efficacy in notifying affected customers and—more generally—from improvements in the manner in which such incidents are handled. The response program requirements might potentially provide substantial benefit in a specific incident, for example in the case of a data breach at an institution that does not currently have an incident response program and is unprepared to promptly respond in keeping with law and best practice. Such an institution will also bear the full costs associated with adopting and implementing procedures complying with the final amendments.[747]

In addition to helping ensure that customers are notified when their data are breached,[748] having reasonably designed strategies for incident assessment and containment ex ante might

---

745 In addition, as discussed above, private funds may be subject to the FTC Safeguards Rule, which requires an incident response plan. *See supra* footnotes 614 and 617 and accompanying text. Hence, we expect that private funds advisers that are registered with the Commission may already have an incident response plan in place.

746 We expect these reviews and updates will result in entities incurring costs generally smaller than the costs of adopting and implementing new procedures. *See supra* section IV.D.1.

747 *See supra* footnote 721 and accompanying text for a discussion of certain quantified costs associated with developing and implementing policies and procedures. *See also infra* section V.

748 The benefits and costs specific to the notification requirements are analyzed in detail in section IV.D.1.b

reduce the frequency and scale of breaches through more effective intervention and improved managerial awareness, providing further indirect benefits. Any such improvements to covered institutions' processes will benefit their customers (e.g., by reducing harms to customers resulting from data breaches), as well as the covered institutions themselves (e.g., by reducing the expected costs of handling data breaches), representing further indirect benefits of the rule.

We lack data on efficacy of incident assessment, incident containment, or customer notification that would allow us to quantify the economic benefits of the final requirements, and no commenter suggested such data. Similarly, we lack data, and no commenter suggested such data, that would allow us to quantify the indirect economic costs, such as reputational cost of any potential increase in the frequency of customer notification or the indirect costs of customer information protection improvements that may be undertaken to avoid such reputational costs. In the aggregate, however, considering the amendments in the context of the baseline, these benefits and costs are likely to be limited. As we have discussed above,[749] all states have previously enacted data breach notification laws with substantially similar aims and, therefore, we think it likely that many institutions have response programs to support compliance with these laws. In addition, we anticipate that larger covered institutions with a national presence—which account for the bulk of covered institutions' customers—have already developed written incident response programs consistent with the proposed requirements in most respects.[750] Thus, the benefits and costs of requiring written incident response programs will be the most significant for smaller covered institutions without a national presence—institutions whose policies affect relatively few customers.

---

below.

749 *See supra* section IV.C.2.a.

750 *See supra* footnote 713 and accompanying text.

In support of the proposed response program requirement, some commenters stated that response programs had benefits beyond the notification of affected individuals. One commenter stated that effective cybersecurity practices and system safeguards, including incident response and notification, were critical for the financial markets and services industry and the regulators tasked with oversight of this sector.[751] Another commenter stated that the costs associated with the incident response programs and more robust notification regime served an important forcing function for entities that might otherwise not adequately invest in safeguards on the front end.[752] This commenter also cited a report stating that having an incident plan is one of the steps organizations can take to protect their data.[753] In addition, in support of the Proposing Release, commenters cited sources offering additional context and evidence of the benefits of incident response programs. A report cited by a commenter states that businesses with an incident response team that tested their incident response plan saw an average of $2.66 million lower breach costs compared to organizations without an incident response team and that did not test their incident response plan.[754] A more recent version of the same report states that businesses which both had an incident response team and tested their incident response plan took 54 fewer days to identify and contain a data breach, compared to businesses that did not have a response

---

751 *See* Google Comment Letter.

752 *See* EPIC Comment Letter. Potential reputational costs, and the associated potential loss of customers, that could result from customer notification will incentivize covered institutions to spend more on information safeguards. However, additional costs associated with the required response program are unlikely to provide such incentives. Once informed, the customers will have the possibility to stop doing business with covered institutions they wish to avoid.

753 *See* EPIC Comment Letter, citing Internet Society's Online Trust Alliance, *2018 Cyber Incident & Breach Trends Report* (July 9, 2019), *available at* https://www.internetsociety.org/wp-content/uploads/2019/07/OTA-Incident-Breach-Trends-Report_2019.pdf.

754 *See* Better Markets Comment Letter. The commenter cited the 2022 IBM Cost of Data Breach Report which finds that the cost of a data breach for organizations without an incident response team and that did not test their incident response plan was $5.92 million, while the costs for organizations with an incident response team that tested its incident response plan was $3.26 million. Equivalent numbers are not available in the 2023 version of the report.

team nor test their incident response plan (252 days as compared to 306 days).[755] This information generally supports our view that incident response programs will have benefits for both covered institutions and their customers. However, because the amendments' requirements differ from those analyzed in these reports, we are unable to use these estimates to precisely quantify the benefits of the amendments in terms of prevention of and response to data breach incidents involving customer information. Nevertheless, to the extent that different reasonably designed incident response programs yield benefits of similar magnitudes, the final amendments will have benefits of similar magnitude for the covered institutions that do not currently have an incident response program in place, with associated benefits for the customers of these institutions.

b. Notification Requirements

The final requirements provide for a Federal minimum standard for data breach notification, applicable to the sensitive customer information of all customers of covered institutions (including customers of other financial institutions whose information has been provided to a covered institution),[756] regardless of their state of residence. The information value of a data breach notification standard is a function of its various provisions and how these provisions interact to provide customers with thorough, timely, and accurate information about how and when their information has been compromised. Customers receiving notices that are more thorough, timely, and accurate have a better chance of taking effective remedial actions, such as placing holds on credit reports, changing passwords, and monitoring account activity.[757]

---

755 *See* 2023 IBM Cost of Data Breach Report.

756 *See* final rule 248.30(d)(5)(i).

757 Commenters agreed that a breach notification allows customers to take mitigating actions limiting the negative effects of a breach. *See, e.g.*, EPIC Comment Letter. One commenter also stated that the value of

These customers will also be better able to make informed decisions about whether to continue to do business with institutions that have been unable to prevent their information from being compromised. Similarly, non-customers who learn of a data breach, for example from individuals notified as a result of the final amendments, might use this information to evaluate their potential use of a covered institution.

As discussed above, all 50 states and the District of Columbia already have data breach notification laws that apply, in varying ways, to compromises of their residents' information.[758] Thus, the benefits of the adopted Federal minimum standard for notification of customers (vis-à-vis the baseline) will vary depending on each customer's state of residence, with the greatest benefits accruing to customers that reside in states with the least informative customer notification requirements.[759]

Unfortunately, with the data available, it is not practicable to decompose the marginal contributions of the various state law provisions to the overall "strength" of state data breach laws. Consequently, it is not possible for us to quantify on a state-by-state basis the benefits of the adopted Federal minimum standard to customers residing in the various states. In considering the benefits of the final notification requirement, we limit consideration to the "strength" of individual provisions of the final amendments vis-à-vis the corresponding provisions under state laws and consider the number of customers that might potentially benefit from each.

---

any required disclosure depended largely on the extent to which it conveyed clear, comprehensible, and usable information. *See* Better Markets Comment Letter.

758 *See supra* section IV.C.2.a. In addition, some covered institutions may be required to share information with certain individuals about certain events under other Federal regulations such as Regulation SCI or the Banking Agencies' Incident Response Guidance. *See supra* section IV.C.2.b.

759 In some cases, large benefits could also accrue to customers that reside in states with broader and more informative breach notification laws if they reside in states where such laws are not applicable to entities in compliance with the GLBA. *See infra* section IV.D.1.b(1).

Similarly—albeit to a somewhat lesser extent—the costs to covered institutions will also vary depending on the geographical distribution of each covered institution's customers. Generally, the costs associated with the final amendments will be greater for covered institutions whose customers reside in states with less informative customer notification laws than for those whose customers reside in states with broader and more informative notification laws. In particular, smaller covered institutions whose customers are concentrated in states where state data breach laws result in less informative customer notification are likely to face higher costs since they may have to issue additional notices to comply with the amendments. The costs associated with notice issuance comprise both administrative costs and reputational costs. Certain costs arising from notice issuance are covered in the Paperwork Reduction Act analysis in section V and are estimated to be on average $5,178 per year per covered institution.[760] We lack data, and no commenter suggested such data, that would allow us to quantify the reputational cost resulting from any potential increase in the frequency of customer notification or the indirect costs of customer information protection improvements that may be undertaken by covered institutions to avoid such reputational costs.

Although some commenters stated that a Federal notification requirement was not needed given existing state law requirements,[761] other commenters supported this proposed provision.[762] One commenter stated that a significant advantage would be that in several states, it would

---

760 This estimate is an annual average for the first three years. The corresponding ongoing annual costs beyond the first three years are estimated to be on average $3,862 per year per covered institution. *See infra* section V.

761 *See, e.g.*, CAI Comment Letter (stating that the proposed amendments' requirements "would simply add another layer on top of these existing requirements and would likely go entirely unnoticed by consumers, while complicating compliance efforts for covered institutions and raising additional compliance and legal risk"). We disagree with these commenters and discuss in detail in the subsections below the benefits of different provisions of the notification requirements over the baseline.

762 *See, e.g.*, ICI Comment Letter 1; IAA Comment Letter 1.

relieve covered institutions from having to issue state-specific breach notices under state law.[763] Another commenter further stated that a Federal breach notification requirement "would satisfy state notice laws that provide exemptions for firms subject to such a requirement, which will help to a degree to reduce the confusion and notification burdens arising from the patchwork of state data breach notification requirements."[764] Another commenter stated that the benefits of a Federal minimum standard would outweigh the burden of the new notification requirements.[765]

In the rest of this section, we consider key provisions of the final notification requirements, their potential benefits to customers (vis-à-vis existing state notification laws), and their costs.

(1) GLBA Safe Harbors

A number of state data breach laws provide exceptions to notification for entities subject to and in compliance with the GLBA. These "GLBA Safe Harbors" may result in customers not receiving any data breach notification from registered investment advisers, broker-dealers, funding portals, investment companies, or transfer agents. The final amendments will help ensure customers receive notice of breach in cases where they may not currently because notice is not required under state law.

Based on an analysis of state laws, we found that 19 states provide a GLBA Safe Harbor.[766] Together, these states account for 24 percent of the U.S. population, or approximately

---

763 *See* ICI Comment Letter 1.

764 *See* IAA Comment Letter 1; *see also supra* footnote 557 and accompanying text. Another commenter stated that the proposed notification requirements would not replace state law requirements and that covered institutions would continue to have to comply beyond the Federal minimum standard for at least 20 states. *See* FSI Comment Letter.

765 *See* FSI Comment Letter.

766 States with exceptions that specifically mention the GLBA include Arizona, Connecticut, the District of Columbia, Delaware, Iowa, Kentucky, Maryland, Minnesota, Missouri, Nevada, New Mexico, Oregon, Rhode Island, South Carolina, South Dakota, Tennessee, Utah, Virginia, and Wisconsin. Additional states